



Utkarsh Arora <utkarsh20143@iiitd.ac.in>

Report issue - Group 32

1 message

Google Forms <forms-receipts-noreply@google.com>
To: utkarsh20143@iiitd.ac.in

Thu, Dec 1, 2022 at 11:55 PM

Thanks for filling out [Report issue - Group 32](#)

Here's what was received.

Report issue - Group 32

Please fill out this form to report an issue/vulnerability in the group 32.

Your email (utkarsh20143@iiitd.ac.in) was recorded when you submitted this form.

Vulnerability type

*

Select the type of vulnerability, or specify a custom one.

☐ XSS

☐ CSRF

☐ Feature bug

☒ Other: DOS

Steps to reproduce

*

Describe the steps to reproduce the vulnerability.

Go to user login

Go to sign in

Register with an email

An OTP is sent to our email

In this email, we can look at the sender. The sender email is a personal institute gmail ID.

These gmail ids have a sending limit of 2000 emails per 24 hours.
If this limit is reached, the email is restricted from sending out any new message for 24 hours.
Thus, OTP verification is blocked, and new users cannot create an account.

Proof of concept

*

Provide a proof of concept for the vulnerability.

I was able to spam OTP request enough times to block the email from sending any more emails.

I used the form to sign up on their website

I used BurpSuite to intercept the GET request

From the GET request, I found out the

"https://192.168.3.50/homepage/ajax_generate_code/?luspizedra@gufum.com" URL that is used to send an OTP to a mail ID.

I wrote a python script to spam a request to this over 2000 times. This took about 3 hours to run.

Thus, the sending limit of the sender email was reached. The sender email cannot send anymore emails. Thus, new users cannot register on the page.

When I tried to send more requests on "https://192.168.3.50/homepage/ajax_generate_code/?luspizedra@gufum.com", I got a server error, which means that it is not able to send OTP requests any more.

When anyone will try to sign up now, the email will not be able to send an OTP, and they will not be able to sign up, thus blocking the signup functionality of the website

Impact

*

Describe the impact of the vulnerability. How bad is it?

Medium severity. The email being spammed leads to the sign-up functionality being blocked for 24 hours, thus no new users can join the website. Thus, the website cannot gain any new users for 24 hours after the attack is completed.

Screenshots/attachments

Provide screenshots or other attachments to help explain the vulnerability.

Submitted files



fcs_32_1_1 - Utkarsh Arora.png



fcs_32_1_2 - Utkarsh Arora.png



fcs_32_1_3 - Utkarsh Arora.png



fcs_32_1_4 - Utkarsh Arora.png

Create your own Google Form
Report Abuse